

Core Banking Mobile Application Replacement

Client: Major Regional Bank — Confidential
Supplier: NileTech Solutions
Document Classification: Historical Technical Proposal — Won
Proposal Reference: NTS-CBMA-042/2024
Delivery Model: Hybrid Agile / Controlled Banking SDLC
Primary Hosting: Bank Private Cloud / On-Premises Banking Zone
Target Platforms: iOS, Android, API Gateway, Core Banking Integration Layer

1. Executive Summary & Project Scope

1.1 Executive Summary

NileTech Solutions was awarded the replacement of the Bank's legacy retail mobile banking application with a **secure, API-first, omnichannel mobile banking platform** supporting retail customers across iOS and Android.

The programme was initiated to address limitations in the incumbent application, including:

- Legacy middleware with limited horizontal scalability.
- Tight coupling between mobile releases and Core Banking changes.
- Inconsistent authentication and session-management mechanisms.
- Limited support for biometric authentication and device binding.
- Fragmented observability across mobile, middleware, and downstream banking services.
- Excessive manual intervention for production incident diagnosis.
- Inability to support rapid introduction of new digital banking products.

The proposed solution introduced an **API-led architecture** between the mobile channels and the Bank's existing Core Banking ecosystem.

Important architectural constraint: NileTech Solutions was not permitted to directly modify the Bank's Core Banking platform. All integration with Core Banking, Cards, Payments, CRM, AML and other systems was required to pass through approved enterprise integration interfaces.

Target Business Capabilities

Capability Domain	Functional Scope	Primary Integration
Customer Authentication	Login, MFA, biometric authentication, device registration	IAM / Active Directory
Accounts	Balances, statements, account details	Core Banking

Capability Domain	Functional Scope	Primary Integration
Transfers	Internal transfers, beneficiary management	Core Banking
Payments	Bill payments, scheduled payments	Payment Gateway / Biller Hub
Cards	Card status, limits, transactions	Card Management System
Customer Profile	Contact information and preferences	CRM
Notifications	Push, SMS, email	Notification Gateway
Security	Device binding, risk checks, session controls	IAM / Fraud Engine
Analytics	Transactional and behavioural telemetry	Enterprise SIEM / Analytics

Scope Boundaries

In Scope

- Native/hybrid mobile application replacement.
- API Gateway configuration and API management.
- Mobile Backend-for-Frontend (**BFF**) services.
- Integration with approved Bank systems.
- Customer authentication and authorization.
- Secure transaction workflows.
- Application observability.
- CI/CD pipelines.
- Automated testing.
- Production deployment.
- Knowledge transfer and operational handover.

Out of Scope

- Core Banking replacement.
- Core Banking database modification.
- Replacement of the Bank's enterprise IAM platform.
- Replacement of the existing Card Management System.
- Physical branch infrastructure.
- ATM software modernization.

1.2 Non-Functional Requirements

The proposed platform was designed against the following target characteristics:

Requirement	Target
Monthly Availability	≥ 99.95%

Requirement	Target
API Availability	≥ 99.99%
Peak Concurrent Sessions	25,000+
API Response — P95	≤ 800 ms for standard read operations
API Response — P95	≤ 2,000 ms for transactional operations
RTO	≤ 60 minutes
RPO	≤ 15 minutes
Horizontal Scaling	Required
Encryption in Transit	TLS 1.2+
Encryption at Rest	AES-256 / platform equivalent
Authentication	OAuth 2.0 / OIDC + MFA
Auditability	Full transaction and administrative audit trail

2. Team Composition & Resourcing

NileTech proposed a **multi-disciplinary delivery organisation** combining banking-domain specialists, mobile engineers, integration architects, cybersecurity resources and DevSecOps engineers.

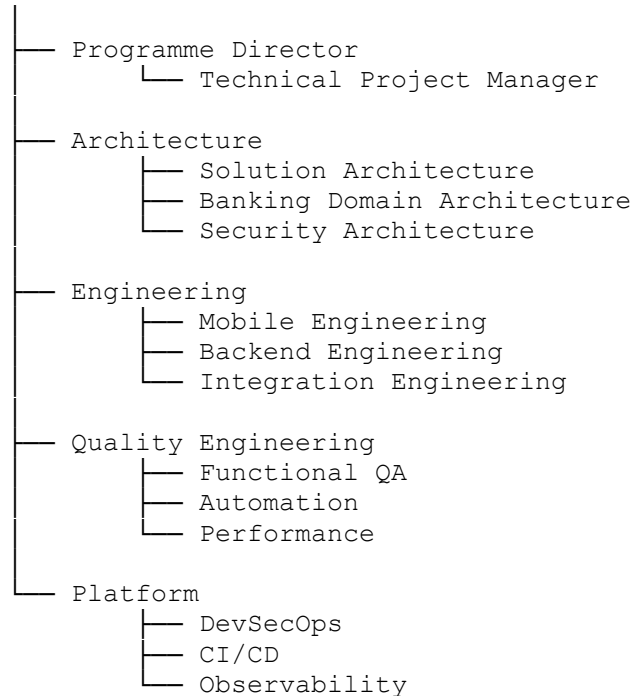
2.1 Core Delivery Team

Role	Years of Exp	Certifications	Allocation %
Programme Director	18	PMP, PRINCE2 Practitioner	20%
Solution Architect	15	TOGAF, AWS/Azure Architecture	80%
Banking Domain Architect	17	Certified Banking Architect	60%
Technical Project Manager	12	PMP, PMI-ACP	100%
Mobile Lead — iOS	11	Apple Certified Professional	100%
Mobile Lead — Android	10	Google Associate Android Developer	100%
Senior iOS Engineer ×2	7–9	Apple Development Certifications	100%
Senior Android Engineer ×2	7–10	Android / Kotlin Certifications	100%
Backend Lead	12	Oracle Java SE, Kubernetes	100%
Senior Backend Engineer ×4	6–9	Java / Spring Certifications	100%
API Integration Lead	13	MuleSoft Certified Developer	80%

Role	Years of Exp	Certifications	Allocation %
Integration Engineer ×3	5–8	MuleSoft / API Management	100%
IAM/Security Architect	14	CISSP, CCSP	50%
Application Security Engineer	8	OSCP, Security+	60%
DevSecOps Lead	11	CKA, Azure DevOps Engineer	80%
DevOps Engineer ×2	6–8	CKA, Terraform Associate	100%
QA Automation Lead	11	ISTQB Advanced	100%
QA Automation Engineers ×4	4–7	ISTQB Foundation	100%
Performance Engineer	9	ISTQB Performance Testing	50%
UX/UI Lead	10	HFI CUA	60%
Business Analyst ×2	8–12	CBAP	100%
Technical Writer / Knowledge Manager	7	ITIL 4 Foundation	30%

2.2 Resourcing Model

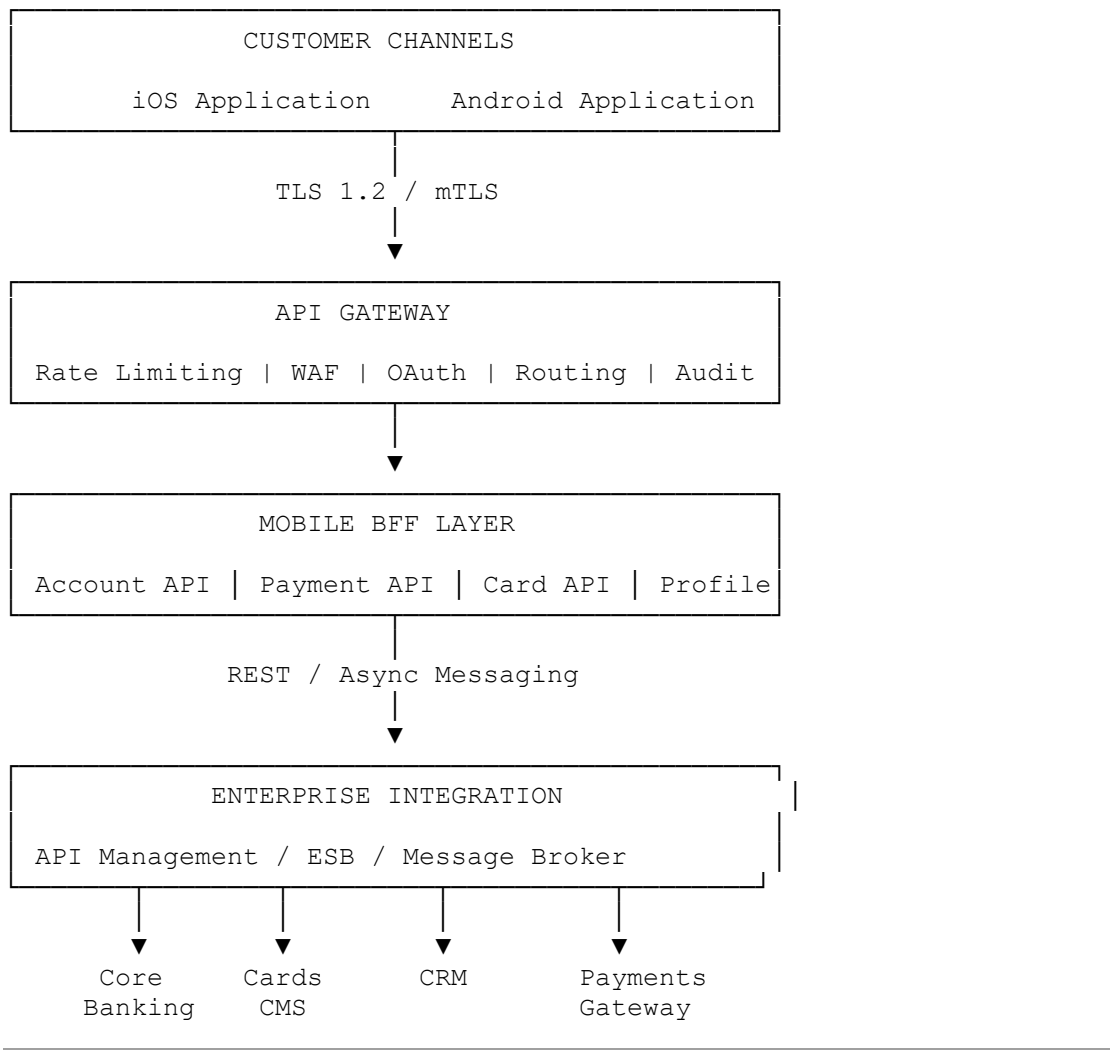
Programme Governance



3. Technical Architecture & Tech Stack

3.1 Target Architecture

The solution followed a **layered API-led architecture** designed to isolate mobile clients from legacy banking systems.



3.2 Technology Stack

Layer	Technology	Purpose
iOS	Swift / SwiftUI	Native iOS application
Android	Kotlin / Jetpack Compose	Native Android application
Backend	Java 21 / Spring Boot	Transaction and customer services
API Gateway	Kong / Enterprise API Gateway	Routing, throttling and policy enforcement
IAM	OAuth 2.0 / OpenID Connect	Authentication and authorization
Integration	MuleSoft / REST / SOAP adapters	Banking-system integration

Layer	Technology	Purpose
Messaging	Apache Kafka	Event-driven communication
Cache	Redis Cluster	Session and frequently accessed data
Database	PostgreSQL	Application metadata and transactional support data
Container Runtime	Kubernetes / OpenShift	Container orchestration
CI/CD	Azure DevOps	Build, test and deployment automation
IaC	Terraform	Infrastructure provisioning
Monitoring	Prometheus / Grafana	Metrics and dashboards
Logging	ELK Stack	Centralised logging
SIEM	Bank Enterprise SIEM	Security monitoring
Testing	JMeter / RestAssured / Appium	Performance/API/mobile automation
Secrets	HashiCorp Vault / Enterprise HSM	Secrets and cryptographic material

3.3 Security Controls

The architecture incorporated security controls at multiple layers:

Application Security

- Certificate pinning.
- Secure local storage using platform keychain/keystore.
- Device registration and binding.
- Root/jailbreak detection.
- Session timeout and token rotation.
- Secure biometric authentication.
- Runtime integrity checks.

API Security

- OAuth 2.0 access tokens.
- API-level authorization scopes.
- Rate limiting.
- Payload validation.
- Schema enforcement.
- Replay protection for transactional operations.
- Correlation IDs for end-to-end traceability.

Transaction Security

Customer Request
↓
Authentication

↓
Device Trust Validation
↓
Transaction Risk Check
↓
Transaction Authorization
↓
OTP / Step-Up Authentication
↓
Core Banking Transaction
↓
Audit Event
↓
Customer Notification

4. Implementation Timeline

The implementation followed a controlled **52-week programme**, including discovery, architecture, engineering, integration, security validation, UAT and production transition.

Phase	Deliverables	Duration in Weeks	Dependencies
1. Mobilisation	Governance model, project charter, RAID log, environments, access matrix	2	Contract award
2. Discovery & Assessment	Legacy application assessment, API inventory, integration catalogue, NFR baseline	4	Bank SME availability
3. UX & Functional Design	Customer journeys, wireframes, accessibility standards, functional specifications	5	Discovery completion
4. Architecture & Security Design	HLD, LLD, threat model, IAM design, API standards	5	Discovery + Security workshops
5. DevSecOps Foundation	CI/CD, repositories, container registry, Kubernetes namespaces, secrets management	4	Environment provisioning
6. Mobile Foundation	Application shell, authentication, navigation, secure storage, telemetry	6	UX approval + IAM
7. Core Banking APIs	Accounts, balances, statements, transfers and beneficiary APIs	10	Integration specifications
8. Cards & Payments	Card services, payment services, bill payment workflows	8	External system readiness

Phase	Deliverables	Duration in Weeks	Dependencies
9. Customer Profile	Profile, preferences, notifications and customer-service integration	5	CRM APIs
10. System Integration Testing	End-to-end integration, negative scenarios, reconciliation testing	5	Development completion
11. Security Testing	SAST, DAST, SCA, penetration testing, mobile security assessment	4	Feature freeze
12. Performance Testing	Load, stress, soak and failover testing	3	Stable SIT build
13. UAT	Business UAT, operational acceptance, defect remediation	4	SIT + security clearance
14. Pilot Deployment	Controlled customer cohort, production monitoring, rollback validation	2	UAT sign-off
15. Production Rollout	Phased rollout, hypercare, operational handover	3	Pilot acceptance
16. Closure	Documentation, KT, final acceptance, support transition	2	Production stabilisation

Critical Path

```

Discovery
  ↓
Architecture
  ↓
IAM + Integration Specifications
  ↓
Backend / API Development
  ↓
Mobile Integration
  ↓
SIT
  ↓
Security + Performance
  ↓
UAT
  ↓
Pilot
  ↓
Production

```

Key Programme Gates

Gate	Acceptance Criterion	Owner
G1 — Architecture Approval	HLD/LLD + Security Architecture approved	Bank Architecture Board

Gate	Acceptance Criterion	Owner
G2 — Development Exit	≥95% planned functionality completed	PMO
G3 — SIT Exit	No open Severity-1 defects	QA + Business
G4 — Security Exit	No unresolved Critical vulnerabilities	CISO
G5 — Performance Exit	P95 targets achieved under agreed load profile	Performance Team
G6 — UAT Exit	Business acceptance achieved	Product Owner
G7 — Production Readiness	DR, rollback, monitoring and operational runbooks approved	Operations

5. SLA & Support Matrix

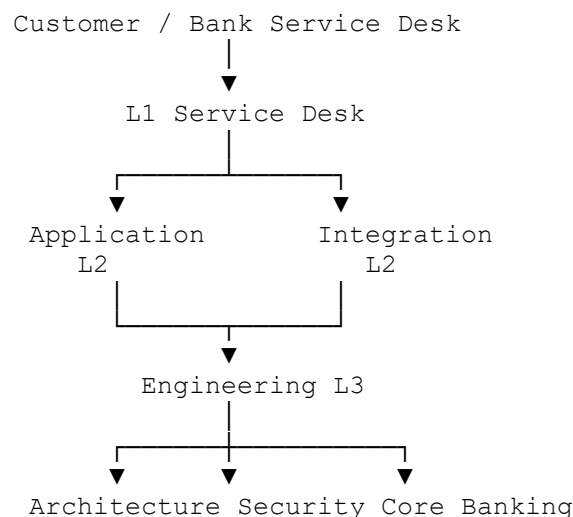
The production service was governed by a **Severity 1–4 incident classification model**.

Severity	Definition	Initial Response	Technical Engagement	Target Workaround	Target Resolution / Restoration
Severity 1 — Critical	Complete service outage, systemic transaction failure, security incident affecting production	15 min	≤30 min	2 hours	4 hours
Severity 2 — High	Major functionality unavailable for significant customer population; degraded transaction processing	30 min	≤1 hour	4 hours	8 hours
Severity 3 — Medium	Non-critical functionality degraded; limited customer/business impact	2 hours	≤4 hours	1 Business Day	3 Business Days
Severity 4 — Low	Cosmetic defect, documentation issue, enhancement request or low-impact defect	4 Business Hours	≤1 Business Day	N/A	5 Business Days / Planned Release

5.1 Support Coverage

Service	Coverage	Monitoring	Escalation
Production Application	24×7×365	Continuous	L1 → L2 → L3
API Gateway	24×7×365	Continuous	L1 → Integration → Architecture
Core Banking Integration	24×7×365	Continuous	Integration → Bank Core Team
Mobile Applications	24×7 incident response	Crash analytics + APM	Mobile L2/L3
Security Events	24×7×365	SIEM	SOC → Security Architect
Scheduled Maintenance	Change window	Planned	CAB approval

Incident Escalation Model



6. Compliance & Acceptance Conditions

The implementation was subject to the Bank's internal security, architecture and change-management policies.

Mandatory controls included:

- **No production credentials in source control.**
- **No direct production database access from developer workstations.**
- All privileged access required **MFA and auditable approval.**
- Production deployments required approved **Change Requests.**
- Security vulnerabilities classified as **Critical** had to be remediated before production release.
- All financial transactions required an immutable audit trail.
- Personally identifiable information (**PII**) was required to be encrypted at rest and protected in transit.

- Application logs were prohibited from containing raw authentication credentials, OTPs or full payment-card data.
- All third-party libraries required Software Composition Analysis (SCA) before release.
- Disaster Recovery procedures were required to be tested before final production acceptance.

Final Acceptance Baseline

The solution would not be considered production-ready unless all of the following were satisfied:

Architecture Approval + Security Clearance + Performance Acceptance + UAT Sign-off + DR Validation + Operational Handover

Historical Proposal Status: Awarded / Successfully transitioned to production.